

TP04 - Analyser une architecture et identifier les failles

Scénario

Une entreprise de billetterie sportive (similaire à RWC23) possède l'architecture suivante :

- Un site web public accessible sur Internet (Apache)
- Le site communique directement avec une base Oracle sur le port 1521
- La base contient : noms, emails, CB hashées, historique d'achats
- Un compte unique "app_admin" avec ALL PRIVILEGES est utilisé par le site ET par les développeurs
- Les développeurs accèdent à la base de production depuis leur poste via VPN
- Un export Data Pump complet est fait chaque nuit et stocké sur un NAS sans chiffrement
- Les mots de passe de la base sont dans un fichier .env sur le dépôt GitLab interne

Travail demandé

1. Dessiner le DFD complet de cette architecture
2. Identifier les trust boundaries et les points de contrôle manquants
3. Appliquer STRIDE sur chaque composant du DFD (Data Flow Diagram)
4. Identifier au minimum 3 chemins d'attaque (attack paths)
5. Classer les vulnérabilités par criticité (Critique / Haute / Moyenne / Faible)
6. Proposer un plan de remédiation priorisé